Jr.Pen 3.1. Passive Reconnaissance

Passive Reconnaissance

Passive reconnaissance mainly gathers information based on publicly available information. Learning Objectives:

- Use `whois` to query domain registration details.
- Use `dig` (and `nslookup` for compatibility) to query DNS records.
- Understand why querying public WHOIS and DNS servers is considered passive.
- Discover subdomains using DNSDumpster and Certificate Transparency logs.
- Gather intelligence on exposed services using Shodan.io.

Step 1: Whois

Whois is used to search for an object in an RFC 3912 database. It helps us to gather information such as contact information, registrar, registration date, registration updates and registration expiration dates, and contact emails, among others.

```
root@ip-10-114-70-118:~# whois tryhackme.com
   Domain Name: TRYHACKME.COM
   Registry Domain ID: 2282723194_DOMAIN_COM-VRSN
   Registrar WHOIS Server: whois.namecheap.com
   Registrar URL: http://www.namecheap.com
   Updated Date: 2025-05-11T14:06:02Z
   Creation Date: 2018-07-05T19:46:15Z
   Registry Expiry Date: 2034-07-05T19:46:15Z
   Registrar: NameCheap, Inc.
   Registrar IANA ID: 1068
   Registrar Abuse Contact Email: abuse@namecheap.com
   Registrar Abuse Contact Phone: +1.6613102107
   Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferP
rohibited
   Name Server: KIP.NS.CLOUDFLARE.COM
   Name Server: UMA.NS.CLOUDFLARE.COM
   DNSSEC: unsigned
   URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-05-29T05:23:21Z <<<
```

```
The Registry database contains ONLY .COM, .NET, .EDU domains and
Registrars.
Domain name: tryhackme.com
Registry Domain ID: 2282723194_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.namecheap.com
Registrar URL: http://www.namecheap.com
Updated Date: 2025-05-11T14:06:03.00Z
Creation Date: 2018-07-05T19:46:15.00Z
Registrar Registration Expiration Date: 2034-07-05T19:46:15.00Z
Registrar: NAMECHEAP INC
Registrar IANA ID: 1068
Registrar Abuse Contact Email: abuse@namecheap.com
Registrar Abuse Contact Phone: +1.9854014545
Reseller: NAMECHEAP INC
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProh
ibited
Registry Registrant ID:
Registrant Name: Redacted for Privacy
Registrant Organization: Privacy service provided by Withheld for Privacy ehf
Registrant Street: Kalkofnsvegur 2
Registrant City: Reykjavik
Registrant State/Province: Capital Region
Registrant Postal Code: 101
```

Using Whois we were able to answer the following question asked on the challenge:

Question 1: When was TryHackMe.com registered? Answer: 20180705

Question 2: What is the registrar of TryHackMe.com? Answer: Namecheap.com

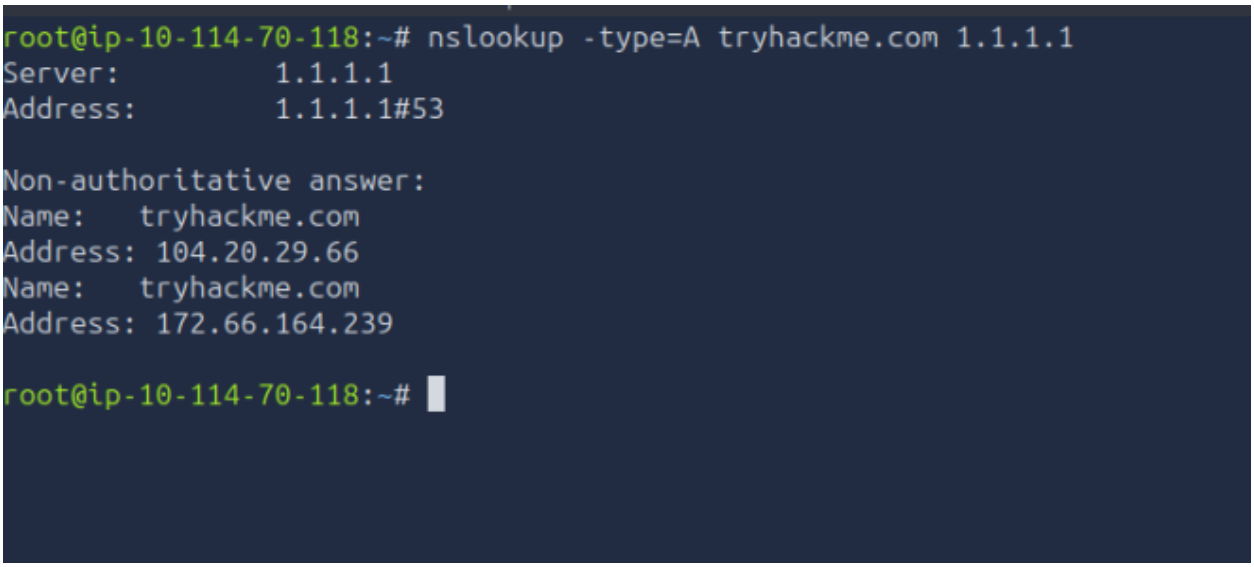
Question 3: Which company is TryHackMe.com using for name servers? Answer: Cloudflare.com

Step 2: Nslookup And dig

Nslookup (Name Server LookUp) is used to query Domain Name System (DNS) servers to map a domain name to an IP as well as other DNS records. We can use it non-interactively and pass arguments. We can use the -type flag, to specify the query type.

Query type	Result
A	IPv4 address(es) for the domain
AAAA	IPv6 address(es) for the domain
CNAME	Canonical Name: an alias that points one domain name to another
MX	Mail Servers: the servers responsible for handling email for the domain
SOA	Start of Authority: the primary name server, admin email, and zone serial number
TXT	Text Records: arbitrary text, commonly used for SPF, DKIM, DMARC, and domain verification

```
nslookup -type=A tryhackme.com 1.1.1.1
```



nslookup (Name Server Lookup) is the older of the two tools.

1. nslookup DOMAIN_NAME performs a simple lookup using your default resolver.
2. nslookup -type=TYPE DOMAIN_NAME [SERVER] specifies a record type and an optional DNS server.

Privacy tip: Use public resolvers like `1.1.1.1` (which supports DNS over HTTPS and DNS over TLS) to avoid your ISP logging your queries.

the 1.1.1.1 part simply tells nslookup: “Use this specific DNS server instead of the system default.”

Question 1: Check the TXT records of thmlabs.com. What is the flag there?

> *Answer: THM{a5b83929888ed36acb0272971e438d78}*

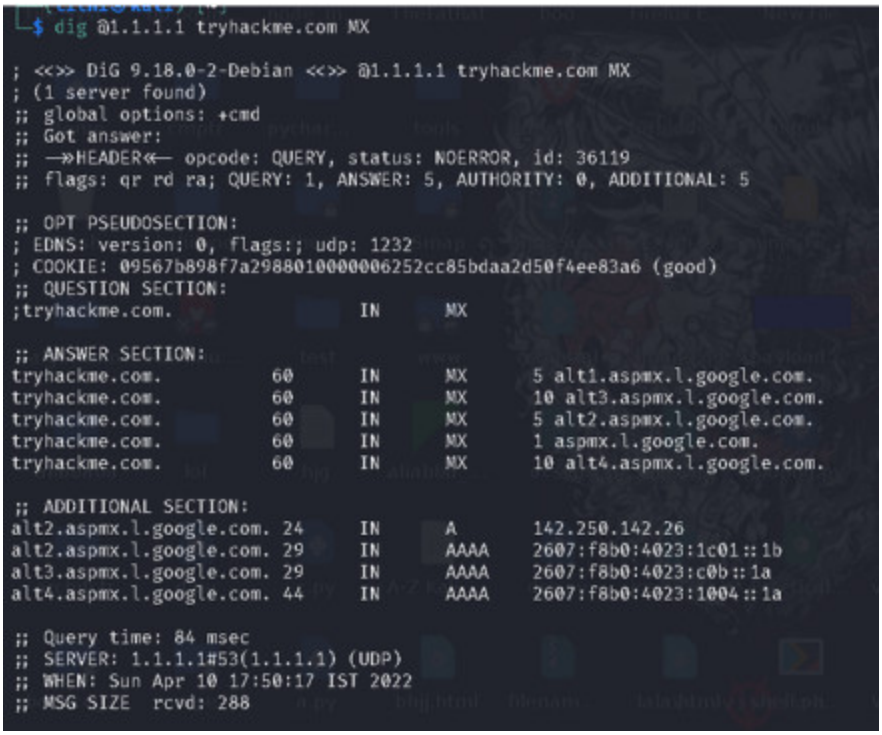
We have solved this question just by repeating similar queries as we saw above for the domain names “thmlabs.com.” and used -type=txt and got the flag successfully.

```
nslookup -type=txt thmlabs.com
```

```
printmessage()
Server:         192.168.1.1
Address:        192.168.1.1#53

Non-authoritative answer:
printsection()
thmlabs.com     text = "THM{a5b83929888ed36acb0272971e438d78}"
```

If we want more advanced DNS queries and additional functionality, we can use dig("Domain Information Groper").dig will return more information, such as the TTL (Time To Live) by default.



```
$ dig @1.1.1.1 tryhackme.com MX

; <<>> DiG 9.18.0-2-Debian <<>> @1.1.1.1 tryhackme.com MX
; (1 server found)
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 36119
;; flags: qr rd ra; QUERY: 1, ANSWER: 5, AUTHORITY: 0, ADDITIONAL: 5

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
; COOKIE: 09567b898f7a298801000006252cc85bdaa2d50f4ee83a6 (good)
;; QUESTION SECTION:
;tryhackme.com.                 IN      MX

;; ANSWER SECTION:
tryhackme.com.          60      IN      MX      5 alt1.aspmx.l.google.com.
tryhackme.com.          60      IN      MX      10 alt3.aspmx.l.google.com.
tryhackme.com.          60      IN      MX      5 alt2.aspmx.l.google.com.
tryhackme.com.          60      IN      MX      1 aspmx.l.google.com.
tryhackme.com.          60      IN      MX      10 alt4.aspmx.l.google.com.

;; ADDITIONAL SECTION:
alt2.aspmx.l.google.com. 24     IN      A       142.250.142.26
alt2.aspmx.l.google.com. 29     IN      AAAA    2607:f8b0:4023:1c01::1b
alt3.aspmx.l.google.com. 29     IN      AAAA    2607:f8b0:4023:c0b::1a
alt4.aspmx.l.google.com. 44     IN      AAAA    2607:f8b0:4023:1004::1a

;; Query time: 84 msec
;; SERVER: 1.1.1.1#53(1.1.1.1) (UDP)
;; WHEN: Sun Apr 10 17:50:17 IST 2022
;; MSG SIZE  rcvd: 288
```

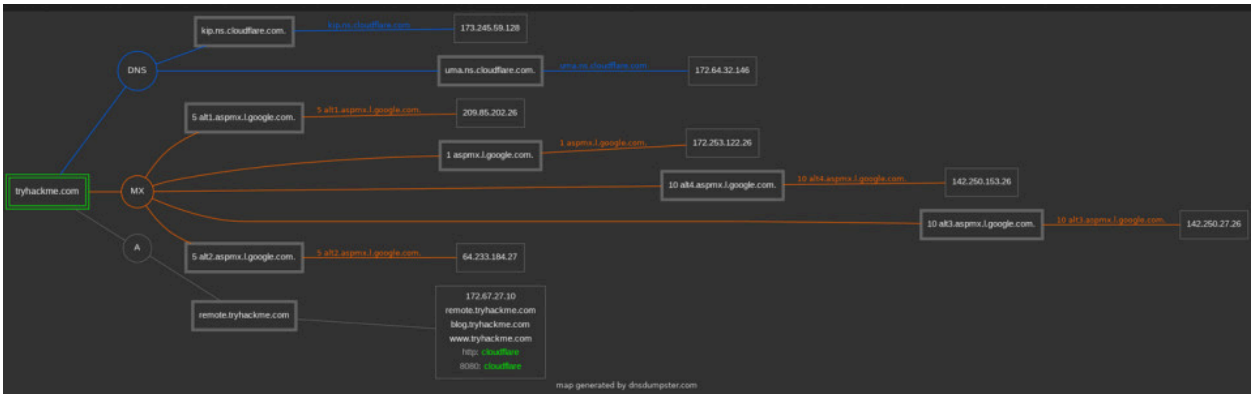
uses the dig DNS tool to query the MX (Mail Exchange) records for tryhackme.com.

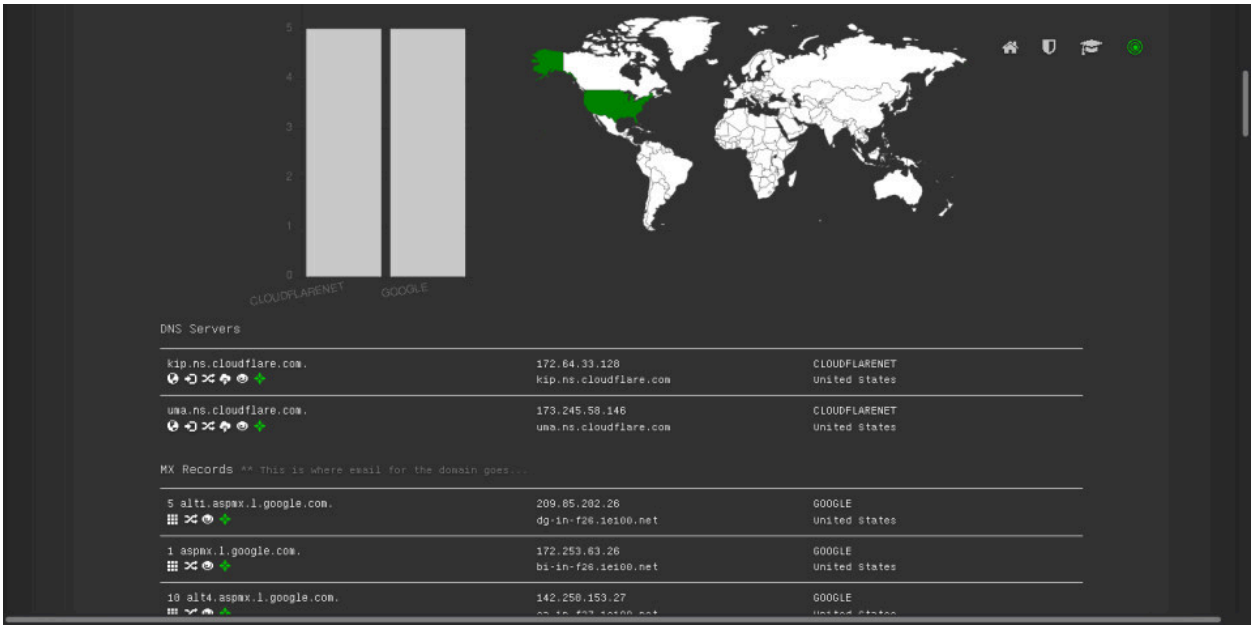
dig → DNS lookup utility ("Domain Information Groper")
@1.1.1.1 → use Cloudflare DNS server
tryhackme.com → domain to query
MX → request mail server records

MX records tell the internet: "Which mail servers handle email for this domain?"

Step 3: DNSDumpster

A lot of useful information can be gathered from the tools above but they are not designed for the enumeration of subdomains. Subdomains can have useful information and servers that can be vulnerable. DNSDumpster.com can be used to discover subdomains, and their IP addresses and attempt to geolocate them.





Certificate Transparency (CT) Logs: **Certificate Transparency** is a public logging framework (mandatory since approximately 2015) that records every SSL/TLS certificate issued by participating Certificate Authorities. Each certificate contains a **Subject Alternative Name (SAN)** field listing the domains and subdomains it covers. By searching these logs, you can discover subdomains without sending any traffic to the target.

To use crt.sh, visit `https://crt.sh` and search for `%.tryhackme.com`. The `%` wildcard matches any subdomain. The results will list every certificate issued for subdomains of `tryhackme.com`, often revealing 10 to 100 times more subdomains than DNSDumpster alone.

From the above graphical view, we found a domain called remote.tryhackme.com which help me to answer the following question:

Question 1: Lookup tryhackme.com on DNSDumpster. What is one interesting subdomain that we would discover in addition to www and blog? Answer: remote

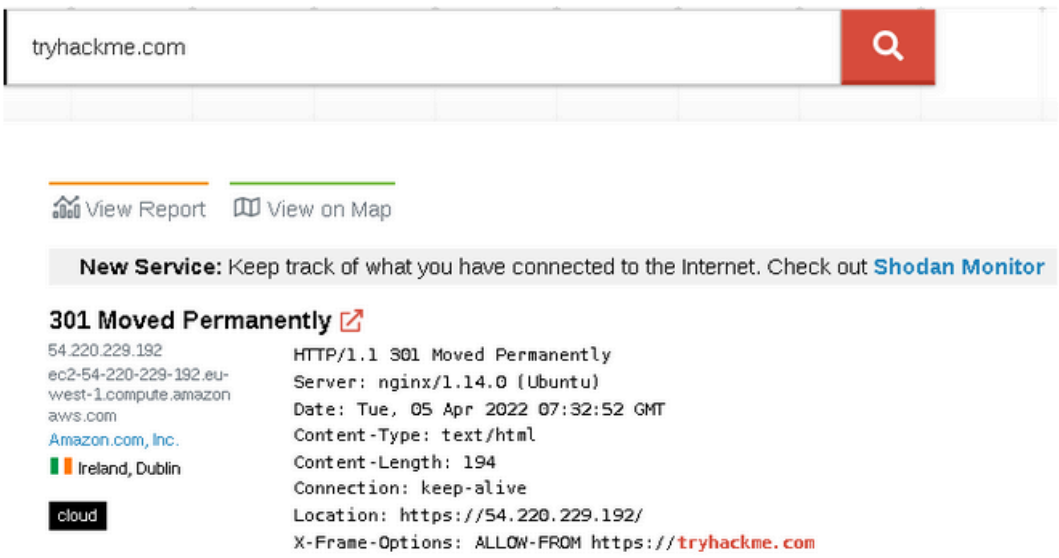
Step 4: Shodan

Shodan.io is used to learn more about our target network. Shodan is like a search engine for devices online, and just because we are not directly connecting to the devices, it will give us a lot of information during the passive research. If we search for tryhackme.com on shodan we will get the following result.

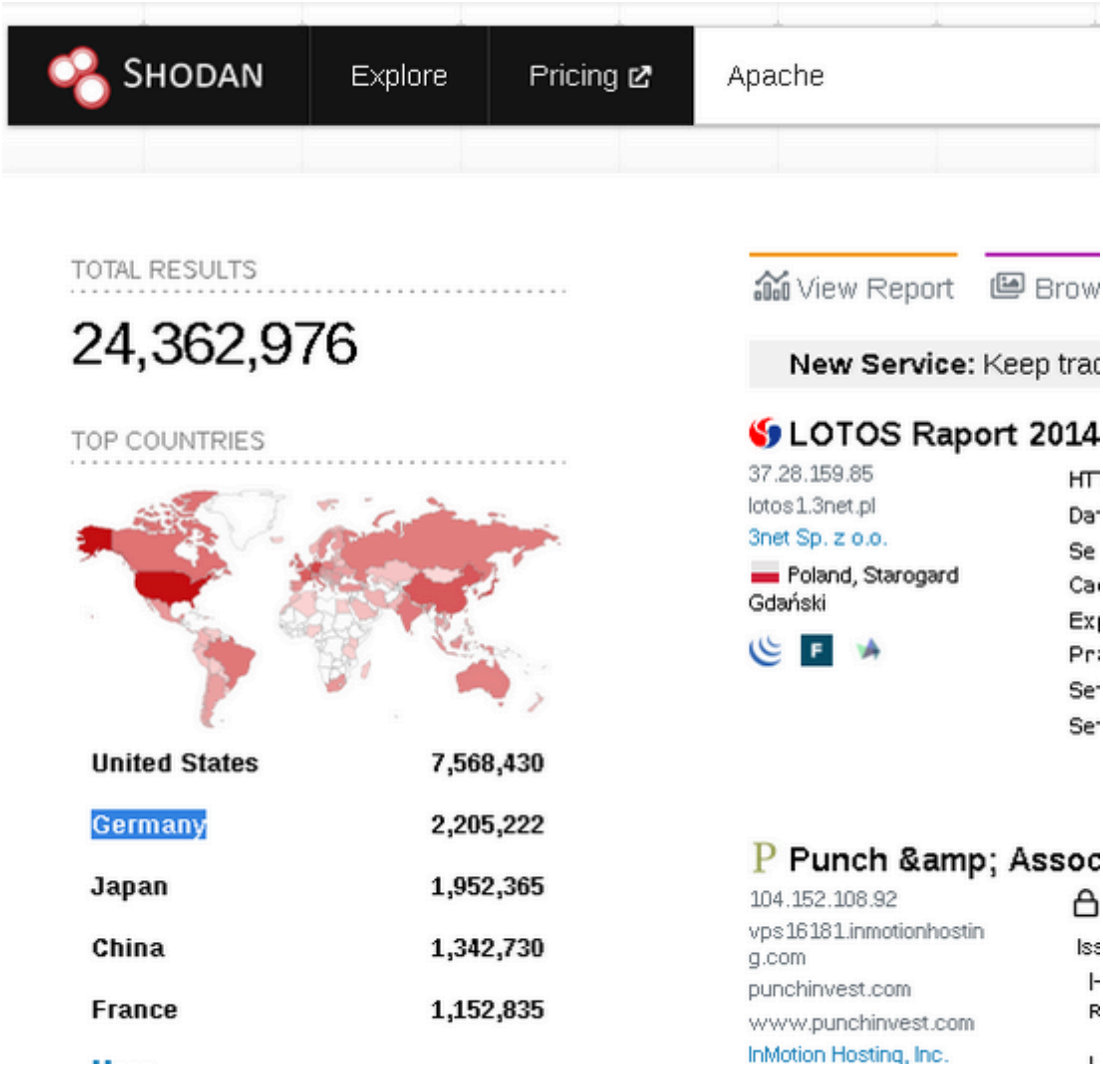
To begin, navigate to `https://www.shodan.io`. No account is required for basic searches. Enter a domain name (e.g., `tryhackme.com`) or an IP address from your earlier DNS lookups (e.g., `104.26.10.229`) into the search bar.

The results page displays a list of matching hosts. Selecting a host opens a detailed view containing the following information:

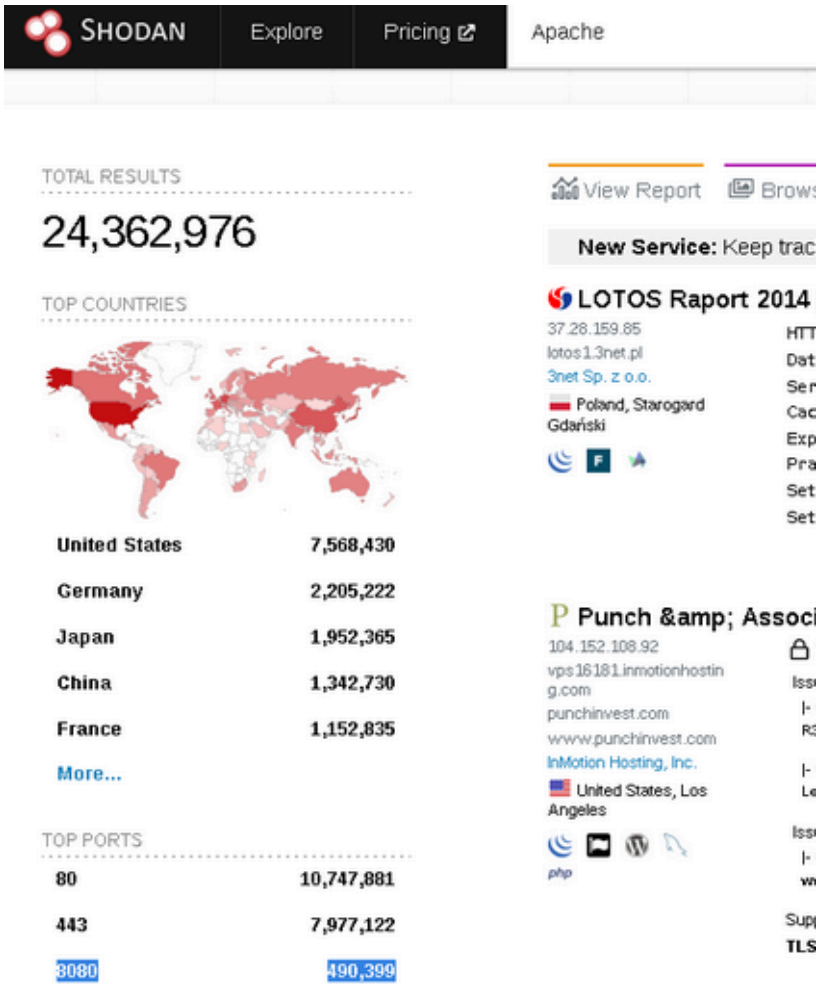
- **IP address** and **ASN** (Autonomous System Number): identifies the network block.
- **Hosting provider/organisation** (e.g., Cloudflare, AWS): reveals the infrastructure behind the domain.
- **Geographic location** (country, city): approximate physical location of the server.
- **Open ports and services**: with version strings and banners (e.g., HTTP server type and version).
- **Tags**: such as `cdn` or `vuln` if a known vulnerability matches the detected service version.



Question 1: According to Shodan.io, what is the 2nd country in the world in terms of the number of publicly accessible Apache servers? Answer: Germany



Question 2: Based on Shodan.io, what is the 3rd most common port used for Apache? Answer: 8080



Question 3: Based on Shodan.io, what is the 3rd most common port used for Nginx? Answer: 8888